Web Vulnerability Prioritiser

Unranked scanner outputs merged into one fix-first list.

Overview

0	0	0	15	14	69.7 s
Critical	High	Medium	Low	No Score	Time taken

29 finding(s) in total: 15 scored, 14 with no score.

Tools parsed

- Nikto: nikto-report.json (32 raw findings)
- ZAP: zap_report.json (33 raw findings)

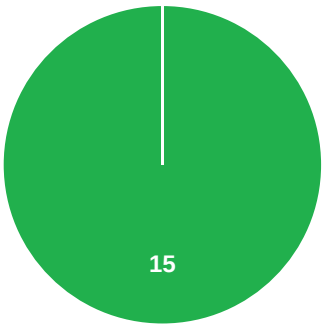
Vulnerabilities merged

- Within each scanner (intra-scanner): Nikto 32 to 19, ZAP 33 to 11. Findings that share at least one reference link are merged, even through a chain. Findings with no references are merged when they share a title.
- Between scanners (inter-scanner): 30 to 29 (1 merged). Findings of different scanners that share at least one reference link are merged.
- Overall: 65 raw findings became 29 findings. Every URL, title and description is kept in a list, so no information is lost.

How the Composite Score was calculated

- Composite Score = EPSS x CVSS (0 to 10). Findings are sorted from the highest score to the lowest, and findings with no score come last.
- A CVE is referenced: the CVSS (NVD) and EPSS (FIRST) scores of that CVE.
- Only a CWE is referenced: the average CVSS and EPSS of the CVEs NVD lists for that CWE.
- Nothing found: a ZAP finding scores its risk code (0 to 3) x 2.5, and any other finding gets no score.
- Severity bands (badges and chart): Low 0 to 3.9, Medium 4 to 6.9, High 7 to 8.9, Critical 9 to 10.

Severity distribution (scored findings)



- Critical: 0 finding(s) (0.0%)
- High: 0 finding(s) (0.0%)
- Medium: 0 finding(s) (0.0%)
- Low: 15 finding(s) (100.0%)

Total scored: 15 finding(s)

Vulnerability Assessment Prioritisation Report

Total Findings: 29

Findings (highest score first)

#1 Apache allows directory listings by requesting. / Apache a... — LOW (2.84)

Scanner: Nikto

Site URL: 127.0.0.1:80/dvwa/?D=A
127.0.0.1:80/dvwa/?N=D
127.0.0.1:80/dvwa/?S=A
127.0.0.1:80/dvwa/?M=A

Method: GET

Description: Apache allows directory listings by requesting.
Apache allows directory listings. Upgrade Apache or disable directory indexing.

References: CVE-2001-0731

#2 Cookie without SameSite Attribute — LOW (2.50)

Scanner: ZAP

Site URL: http://localhost:4280

Method: GET

Description: A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.

References: https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

#3 /images: The web server may reveal its internal or real IP... — LOW (1.99)

Scanner: Nikto

Site URL: 127.0.0.1:80/dvwa/images

Method: GET

Description: /images: The web server may reveal its internal or real IP in the Location header via a request to with HTTP/1.0. The value is "172.17.0.2".

References: CVE-2000-0649

#4 The remote server may allow directory listings through Web... — LOW (0.25)

Scanner: Nikto

Site URL: 127.0.0.1:80/dvwa/?PageServices
127.0.0.1:80/dvwa/?wp-cs-dump

Method: GET

Description: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled.

References: CVE-1999-0269

#5 Abyss 1.03 reveals directory listing when multiple /'s are...

LOW (0.14)

Scanner: Nikto

Site URL: 127.0.0.1:80/dvwa///
///
///
/////////////////////////

Method: GET

Description: Abyss 1.03 reveals directory listing when multiple /'s are requested.

References: CVE-2002-1078

#6 Content Security Policy (CSP) Header Not Set

LOW (0.11)

Scanner: ZAP

Site URL: http://localhost:4280
http://localhost:4280/login.php
http://localhost:4280/sitemap.xml

Method: GET

Description: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP
https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
https://www.w3.org/TR/CSP/
https://w3c.github.io/webappsec-csp/
https://web.dev/articles/csp
https://caniuse.com/#feat=contentsecuritypolicy
https://content-security-policy.com/

#7 X-Content-Type-Options Header Missing

LOW (0.11)

Scanner: ZAP

Site URL: http://localhost:4280
http://localhost:4280/dvwa/css/login.css
http://localhost:4280/dvwa/images/login_logo.png
http://localhost:4280/login.php
http://localhost:4280/robots.txt

Method: GET

Description: The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.

References: https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)
https://owasp.org/www-community/Security_Headers

#8 X-Frame-Options header is deprecated and was replaced with... LOW (0.05)

Scanner: Nikto, ZAP

Site URL: 127.0.0.1:80/dvwa/
http://localhost:4280
http://localhost:4280/login.php

Method: GET

Description: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

#9 HTTP Only Site LOW (0.05)

Scanner: ZAP

Site URL: http://localhost:4280/

Method: GET

Description: The site is only served under HTTP and not HTTPS.

References: https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html
https://letsencrypt.org/

#10 Parameter Tampering LOW (0.03)

Scanner: ZAP

Site URL: http://localhost:4280/login.php

Method: POST

Description: Parameter manipulation caused an error page or Java stack trace to be displayed. This indicated lack of exception handling and potential areas for further exploit.

References: -

#11 In Page Banner Information Leak LOW (0.01)

Scanner: ZAP

Site URL: http://localhost:4280/sitemap.xml

Method: GET

Description: The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use.

References: https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

#12 Server Leaks Information via "X-Powered-By" HTTP Response... LOW (0.01)

Scanner: ZAP

Site URL:
http://localhost:4280
http://localhost:4280/
http://localhost:4280/login.php
http://localhost:4280/dvwa/css/login.css
http://localhost:4280/dvwa/images/login_logo.png
http://localhost:4280/robots.txt

Method:
GET
POST

Description: The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.

References:
https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
https://www.troyhunt.com/shhh-dont-let-your-response-headers/
https://httpd.apache.org/docs/current/mod/core.html#servertokens
https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10)

#13 Authentication Request Identified LOW (0.00)

Scanner: ZAP

Site URL: http://localhost:4280/login.php

Method: POST

Description: The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields.
If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.

References: https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/

#14 Session Management Response Identified LOW (0.00)

Scanner: ZAP

Site URL:
http://localhost:4280
http://localhost:4280/login.php

Method:
GET
POST

Description: The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

References: https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

#15 User Agent Fuzzer

LOW (0.00)

Scanner: ZAP

Site URL: http://localhost:4280
http://localhost:4280/
http://localhost:4280/dvwa
http://localhost:4280/dvwa/css
http://localhost:4280/dvwa/images

Method: GET

Description: Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

References: https://owasp.org/wstg

#16 Directory indexing found.

NO SCORE

Scanner: Nikto

Site URL: 127.0.0.1:80/dvwa/
127.0.0.1:80/dvwa/./
127.0.0.1:80/dvwa//
127.0.0.1:80/dvwa/%2e/
127.0.0.1:80/dvwa///
127.0.0.1:80/dvwa/css/
127.0.0.1:80/dvwa/includes/
127.0.0.1:80/dvwa/images/
127.0.0.1:80/dvwa//
//
//
//////////////////////////

Method: GET

Description: Directory indexing found.

References: CWE-548

#17 OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .

NO SCORE

Scanner: Nikto

Site URL: 127.0.0.1:80/dvwa/

Method: OPTIONS

Description: OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .

References: -

#18 RFC-1918 IP address found in the 'location' header.

NO SCORE

Scanner: Nikto

Site URL: 127.0.0.1:80/dvwa/images

Method: GET

Description: RFC-1918 IP address found in the 'location' header. The IP is "172.17.0.2".

References: https://portswigger.net/kb/issues/00600300_private-ip-addresses-disclosed

#19 Suggested security header missing: content-security-policy.

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa/
Method: GET
Description: Suggested security header missing: content-security-policy.
References: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP

#20 Suggested security header missing: referrer-policy.

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa/
Method: GET
Description: Suggested security header missing: referrer-policy.
References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy

#21 Suggested security header missing: strict-transport-secur...

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa/
Method: GET
Description: Suggested security header missing: strict-transport-security.
References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security

#22 Suggested security header missing: permissions-policy.

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa/
Method: GET
Description: Suggested security header missing: permissions-policy.
References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy

#23 Suggested security header missing: x-content-type-options.

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa/
Method: GET
Description: Suggested security header missing: x-content-type-options.
References: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options

#24 Apache/2.4.25 appears to be outdated (current is at least...

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa/
Method: HEAD
Description: Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
References: -

#25 Appending '/./' to a directory allows indexing.

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa/./
Method: GET
Description: Appending '/./' to a directory allows indexing.
References: -

#26 Apache on Red Hat Linux release 9 reveals the root direct...

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa//
Method: GET
Description: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
References: -

#27 Weblogic allows source code or directory listing, upgrade...

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa/%2e/
Method: GET
Description: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher.
References: https://web.archive.org/web/20171102042459/http://www.securityfocus.com/bid/2513

#28 This might be interesting.

NO SCORE

Scanner: Nikto
Site URL: 127.0.0.1:80/dvwa/css/
127.0.0.1:80/dvwa/includes/
Method: GET
Description: This might be interesting.
References: -

#29 The X-Content-Type-Options header is not set.

NO SCORE

Scanner:	Nikto
Site URL:	127.0.0.1:80/dvwa/
Method:	GET
Description:	The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
References:	https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/